AUTHENTICATION - USERNAME ENUMERATION

TryHackMe Learning & Practical Report

Prepared by	Belal Rabea Khalifa
Program	IqraSec Academy, WAPT Internship (Cohort 02), Phase 1
Task	4. Common Web Vulnerabilities - Authentication & Access Control
Platform	PortSwigger Web Security Academy
Lab	Username enumeration via different responses
Link	portswigger.net/web-security/authentication/password-based/lab-username-enumeration-via-different-responses
Focus	username enumeration, Burp Intruder (Sniper), password brute-force
Status	Solved
Date	October 2026

1. Objective

Solve the PortSwigger lab "Username enumeration via different responses": find a valid username from the login page's responses, then brute-force that user's password and log in.

2. Concept / Understanding

- Some login forms answer differently for a wrong username than for a wrong password (different error text, response length, or status code). This lets an attacker find valid usernames before trying passwords.
- **Two-stage attack:** first find a valid username (try many usernames with one fixed password and compare the responses), then brute-force the password for that one username only. This is faster and sends far fewer requests than trying every username/password pair together.
- **Burp Intruder, Sniper attack:** marks one position in the request (§...§) and tries a list of payloads in that position only, one at a time.
- **Signals to compare in the results:** response length, the error message text, and the HTTP status code. A 302 Found with a Location header usually means a successful login (redirect), while 200 OK with an error message means it failed.

3. Practical Work

Lab: Username enumeration via different responses. I did the following steps:

#	Step	What I did / found
1	Opened the lab's login page and submitted a test login (username ayam, a random password), with Burp Proxy intercepting.	Captured the POST /login request with the body username=ayam&password;=goreng.
2	Sent the request to Intruder and selected only the username value as the payload position (username=§ayam§&password=goreng).	Position set for a Sniper attack.

3	Loaded a list of candidate usernames (carlos, root, admin, test, guest, info...) as the payload, and started the attack.	Got one response per username, all status 200.
4	Sorted the results by response Length.	The username **adam** gave a different length (3354) and a different message: "Incorrect password", instead of "Invalid username" for the others. So **adam** is a valid username.
5	Built a new request with username=adam, and marked only the password value as the payload position (password=§goreng§).	Position set for the password brute-force.
6	Loaded a list of candidate passwords (123456, password, 12345678, qwerty, 123456789, 12345, michael...) and started the attack.	Most attempts returned 200 OK. The password **michael** returned **302 Found** with a Location header, which means a successful login.
7	Logged in with adam / michael.	Reached the My Account page. Lab marked as Solved.

4. Tools Used

- Burp Suite (Proxy and Intruder)
- Web browser
- PortSwigger Web Security Academy lab

5. Evidence

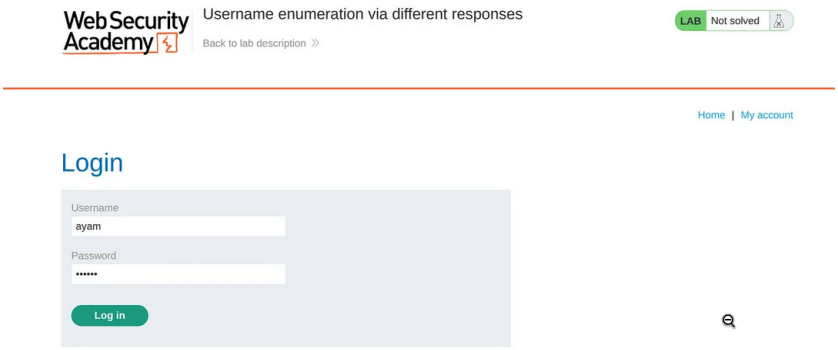


Figure 1: the lab's login page, status Not solved, before starting.

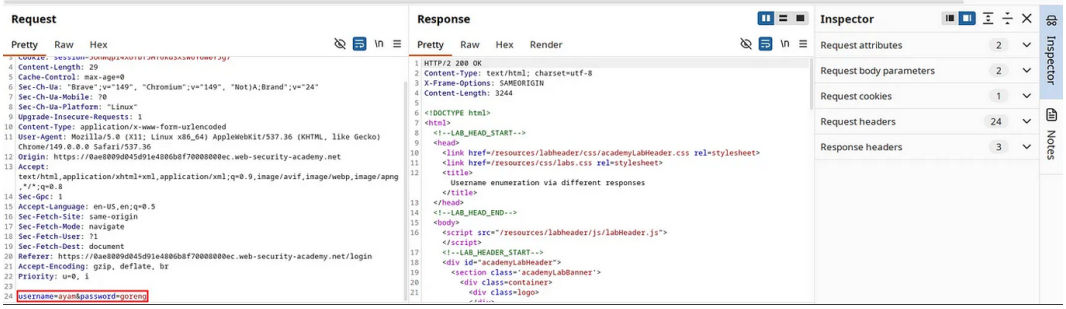


Figure 2: the captured POST /login request, with username=ayam&password;=goreng at the bottom.

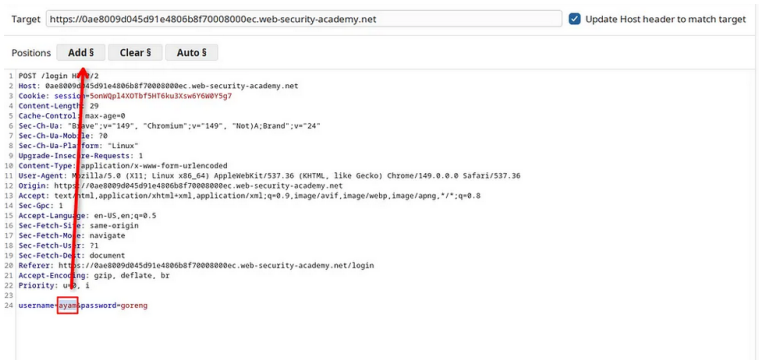


Figure 3: in Intruder, only the username value is marked as the payload position.

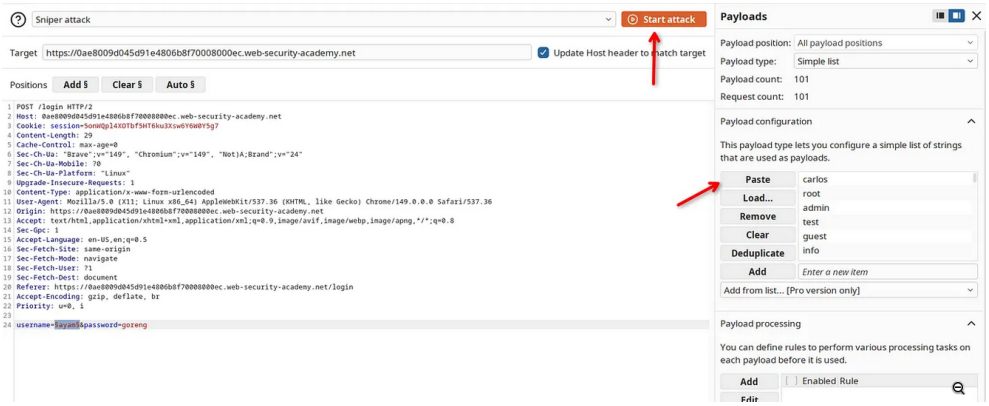


Figure 4: Sniper attack configured with the list of candidate usernames, ready to start.

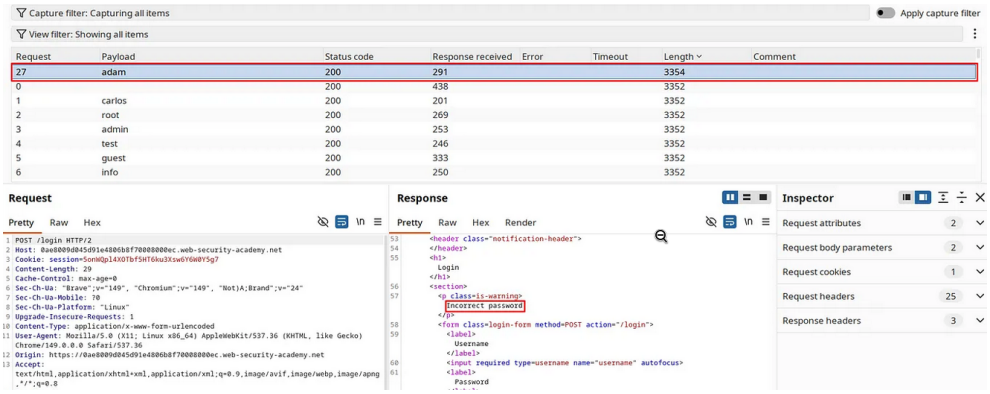


Figure 5: attack results sorted by length. The username adam has a different length and shows "Incorrect password".

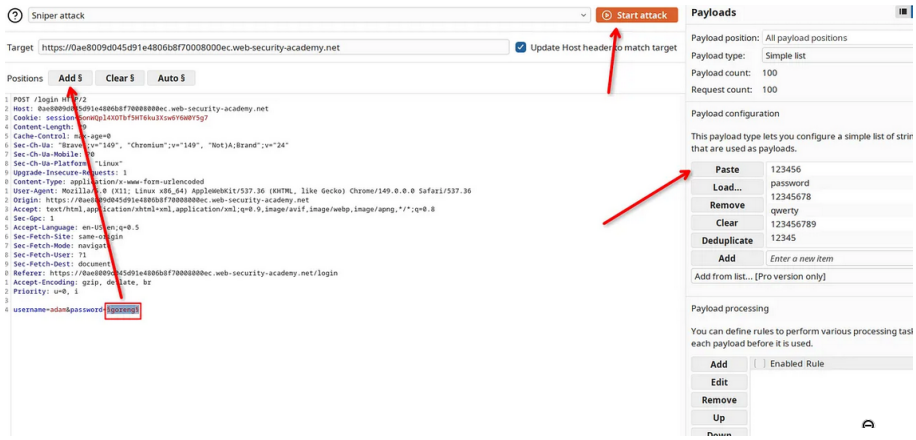


Figure 6: new request with username=adam, password value marked as the payload position, with the candidate password list loaded.

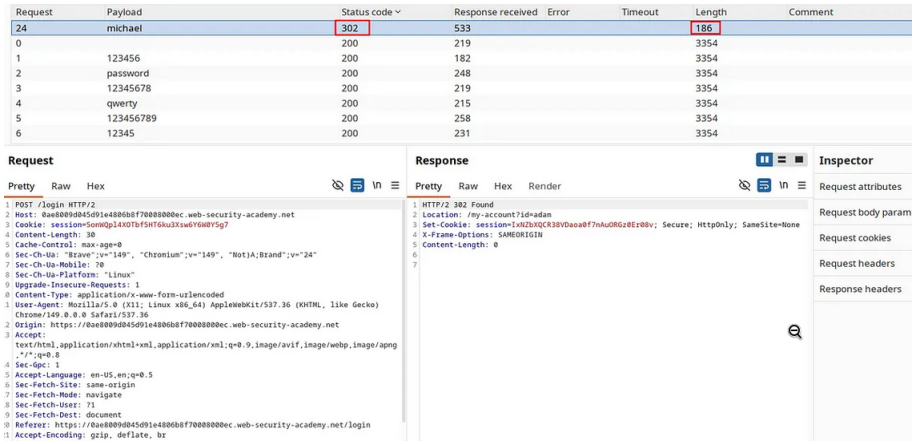


Figure 7: password attack results. The password michael returns 302 Found (success), while the others return 200.

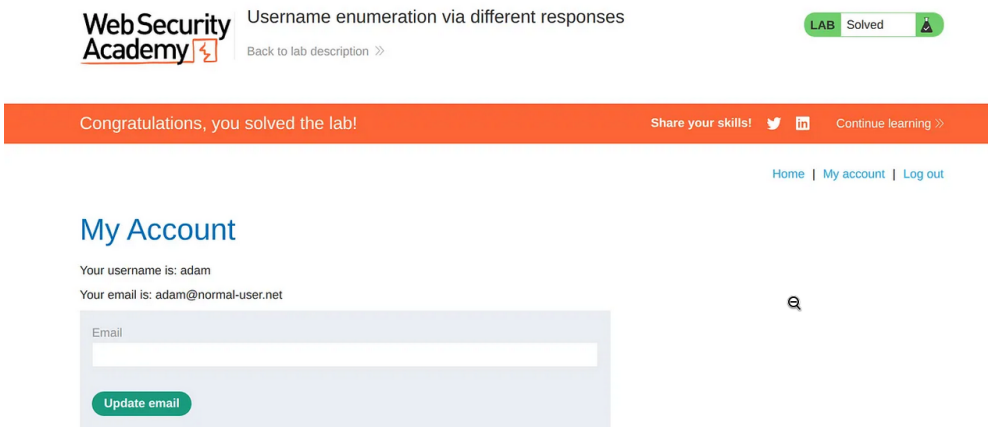


Figure 8: logged in as adam. The lab shows "Congratulations, you solved the lab!".

6. Result

Solved the lab. Found the valid username adam by comparing Intruder responses, then found the password michael by brute-forcing only that username, and logged in to the account.

7. Key Learnings

- Splitting the attack (usernames first, then password for the found user) is much faster and quieter than trying every combination together.
- Small differences between responses (length, error text, status code) can reveal whether a username is valid.
- A 302 redirect is a strong sign of a successful login, compared to a 200 OK with an error message.
- Burp Intruder's Sniper attack is the right mode when only one value needs to be tested at a time.

8. Impact and Remediation

Impact: an attacker can find real usernames and then brute-force only their passwords, which makes account takeover much faster and more likely to succeed than guessing both values at once.

Remediation:

- Return the exact same error message and a similar response length and timing for both a wrong username and a wrong password (for example, always "Invalid username or password").
- Add rate limiting and account lockout (or CAPTCHA) after repeated failed login attempts.
- Use multi-factor authentication so a found password is not enough on its own.